

دليل إجراءات الاستجابة للحوادث والتهديدات السيبرانية

الصفحة 1 من 3 | كود المستند: doc_ar_11

المرحلة الأولى: تصنيف مستويات خطورة الحوادث السيبرانية

تقسم الحوادث السيبرانية إلى أربعة مستويات رئيسية: P1 (حرج جدا)، P2 (عالي الخطورة)، P3 (متوسط)، P4 (منخفض).

المستوى P1 يشمل حوادث تعطل البنية التحتية الحيوية، واختراق شبكات التحكم الصناعي، وتفشي برمجيات الفدية الشامل.

المرحلة الثانية: إجراءات وزمن الاحتواء الفوري للحدث

يجب على فريق الاستجابة بدء إجراءات العزل المنطقي وعزل الأنظمة المتأثرة لحوادث P1 خلال مدة أقصاها ساعة واحدة من تأكيد الحادث.

يتعين إصدار تقرير فني أولي بالأدلة الجنائية والمسارات المخترقة خلال 12 ساعة من بدء التعامل مع الحادث السيبراني.

المرحلة الثالثة: جمع الأدلة الرقمية وسلسلة الحيازة القانونية

يجب الحفاظ على سلامة الأدلة الرقمية واستخدام وحدات قراءة الأقراص المانعة للكتابة (Write-blockers) أثناء الاستحواذ على البيانات.

يلزم حساب وتوثيق القيمة التجزئية التشفيرية المشفرة (Cryptographic Hash) باستخدام خوارزمية SHA-256 لكافة الصور الجنائية المستخلصة.

يجب توثيق سجل سلسلة الحيازة (Chain of Custody) متضمنا اسم المحقق، تاريخ ووقت التحريز، والرقم التسلسلي للجهاز المحرز.

المرحلة الرابعة: القضاء على التهديد والتعافي وإعادة التشغيل

تشمل مرحلة القضاء على التهديد إزالة كافة الأبواب الخلفية، وإلغاء صلاحيات الحسابات المخترقة، وتطبيق التحديثات الأمنية العاجلة.

لا يسمح بإعادة ربط الأنظمة المعالجة بالشبكة الإنتاجية إلا بعد إجراء فحص أمني شامل ومراقبة سلوكية مكثفة لمدة 48 ساعة متواصلة.

المرحلة الخامسة: استخلاص الدروس المستفادة والتقرير النهائي

يجب عقد اجتماع استعراض الدروس المستفادة وتقديم التقرير النهائي للحدث خلال مدة لا تتجاوز 10 أيام عمل من تاريخ إغلاق الحادث.